



Cyber Insurance Policy Evaluation & Risk Alignment

Objective

You will evaluate cyber insurance options based on the unique needs, risks, and security posture of **your own company**. This assignment reinforces practical application of cyber insurance principles and real-world decision-making..

Instructions

As the cybersecurity officer (or advisor) for your company, you have been asked to recommend a cyber insurance policy to protect against potential financial losses from cyber incidents. You will assess your company's risk profile, define coverage requirements, evaluate real-world policies, and develop a readiness checklist.

Complete each part of the assignment and submit a professional report (4–6 pages, not including appendices).

Part 1 – Company Profile Review (Provided in Appendix A)

1) Summary of Sentinel Shield -

- a) **Description** – Sentinel Shield is a medium-sized firm that provides 24/7 managed IT support services mainly in the financial sector. The company handles sensitive client data, assists with regulatory compliance with GLBA and PCI DSS, while maintaining our Incident Response team.

- b) **Current Cybersecurity Posture** – Our current standing with cybersecurity is on a fundamental level as we have taken measures to add firewalls, antivirus protections, and basic incident response protocols. We are still aware of the evolving nature of Cybersecurity and still maintain a security focus framework to provide our services which handle sensitive information. Since we are focusing our efforts on the financial sector we have more of the average risk profile due to how this financial world works. Since we have provided, I will say a more balanced security framework we may need to increase our security to handle more complex threats like Ransomware or social engineering campaigns. This is our current standing of Sentinel Shield cybersecurity framework.

2) Top 3 Risks – Sentinel Shield Faces

- a) **Ransomware Attacks** – Our biggest risk is going to be Ransomware attacks due to the volume of sensitive financial data our company Sentinel shield manages. A successful ransomware attack could encrypt critical client data and systems rendering operation operable until a ransom is paid. There are multiple problems when it comes to these types of attacks and sentinel shields need to be prepared.
- b) **Third-Party Liability** – Another risk is our negligence of handling vulnerabilities within Sentinel Shield. If our client experiences a data breach by our services, we could face third-party liability fines. This type of risk is situational as the client could seek damages for the losses that were incurred. If the reaches on wide scale, we could face a class action lawsuit which could incur damages leading to long-term reputational harm for us. For this we need to take initiative, or our services maintain our security the best we are capable of showing our clients our message or strong and dependable.
- c) **Regulatory Non-Compliance Fines** – Another reason for being in the financial sector we are subject to follow stringent regulatory obligations like

GLBA and PCI DSS. If we fail to comply and maintain an appropriate response or have data breach of client information it could result in fines, audits, and expensive breach recovery efforts. With that even ongoing investigations can divert internal resources which can harm client confidence. That is why we need to focus on our framework to stay in compliance with these regulations to at least minimize the potential fines and have our incident response team ready for initiative-taking response and investigation handle effectively.

3) Estimated Financial Exposure due to Cyber Event

- a) **Ransomware Attack Costs** - Ransom demands could range from **\$500,000 to \$1.5 million**, depending on the scale and sensitivity of exfiltrated data. Business interruption, negotiation costs, forensic investigations, and system restoration could add another **\$500,000 to \$1 million**. Total estimated ransomware-related costs: **\$1 million to \$2.5 million**.
 - b) **Regulatory Fines and Penalties** - Regulatory penalties for non-compliance following a breach could range between **\$500,000 and \$1 million**, based on the number of affected records and whether negligence is identified. Additional costs include mandatory breach notification efforts, independent security audits, and legal counsel.
 - c) **Third-Party Lawsuit and Settlement Costs** - A significant breach affecting multiple financial clients could trigger third-party lawsuits, class-action settlements, and insurance claims. Potential damages could range from **\$3 million to \$6 million** depending on the extent of client losses and any punitive damages awarded.
 - d) **Overall Estimated Financial Exposure Range** - **\$4.5 million to \$9.5 million per major cyber event**
-

Part 2 – Policy Requirements Definition

- 1. **Type of Coverage Needed:** Based on Sentinel Shield’s industry (financial sector IT support) and services (including handling client-sensitive data, managing regulatory compliance, and incident response activities), both first-party and third-party coverage are required.
 - **First-Party Coverage** (Protects Sentinel Shield directly):
 - Data breach response (for company and employees).
 - Cyber extortion and ransomware attack costs.
 - Business interruption and downtime recovery.
 - Digital asset restoration (data recovery).
 - Crisis management expenses (PR, legal counsel).
 - **Third-Party Coverage** (Protects Sentinel Shield against lawsuits from clients or partners):
 - Liability from failing to prevent a client’s breach.
 - Regulatory defense and penalty coverage (important for financial compliance like GLBA, PCI DSS).
 - Legal costs due to lawsuits for financial loss from clients or partners.
 - Notification costs to affected parties in case of a breach involving customer data.
- 2. **Recommended Coverage Limits:** Given Sentinel Shield’s medium size and the high regulatory and financial stakes involved in supporting financial institutions, the following coverage limits are recommended:

Coverage Type	Minimum Coverage	Maximum Coverage
First-Party Cyber Insurance	\$2 million	\$5 million
Third-Party Liability Coverage	\$3 million	\$6 million
Crisis Management & Regulatory Fines	\$500,000	\$1 million

- **Reasoning:**
 - Financial institutions face regulatory fines often exceeding hundreds of thousands of dollars.

- A single ransomware incident could cost upwards of \$1–2 million, including negotiation, downtime, recovery, and customer notifications.
- Class-action lawsuits or regulatory breaches could exceed \$3 million depending on the severity.

3. **Key Exclusions to Avoid:** To maximize protection, Sentinel Shield must carefully review and avoid policies with the following exclusions:

<i>Exclusion</i>	<i>Risk to Company</i>	<i>Action</i>
<i>Acts of War/Terrorism Exclusion</i>	Cyberattacks from nation-state actors could be excluded. Financial companies are frequent targets.	Seek a policy that narrows or eliminates this exclusion or offers coverage for cyberterrorism.
<i>Negligence or Lack of Security Maintenance</i>	Claims could be denied if the company is found negligent in maintaining cybersecurity practices (e.g., no MFA, outdated patches).	Choose a policy that allows reasonable periods for remediation and focuses on gross negligence, not minor missteps.
<i>Prior Knowledge Clause</i>	May deny claims if the company knew of vulnerabilities before policy inception.	Clarify with insurers and seek policies with flexible definitions of "prior knowledge."
<i>Failure to Maintain Insurance Standards</i>	Denials based on failing to meet detailed technical standards (e.g., backup frequency, endpoint security).	Negotiate or seek clear language around reasonable compliance efforts rather than strict technical conditions.

Part 3 – Insurance Market Comparison

To ensure Sentinel Shield’s cyber risk is adequately managed, three leading cyber insurance providers were evaluated based on their coverage types, limits, deductibles, premiums, and customer reputation. The goal was to select a policy that meets the company's unique needs, particularly given our financial sector focus, ransomware exposure, and regulatory compliance requirements.

<i>Provider</i>	<i>Coverage Types</i>	<i>Coverage Limits</i>	<i>Deductibles</i>	<i>Premiums</i>	<i>Customer Reputation</i>
<i>Chubb</i>	Comprehensive first party and third-party coverage, including data breaches, business interruption, cyber extortion, and social engineering fraud.	Up to \$100 million	Varies based on risk profile	Higher end; scales with exposure	A++ AM Best rating; strong financial stability but mixed customer service reviews.
<i>Beazley</i>	Specialized breach response, regulatory investigations, ransomware, and third-party liability coverage.	Up to \$15 million (third-party); \$5 million (breach response).	Typically, \$2,500–\$5,000	Competitive for mid-sized firms	4.3/5 rating (Advisor Smith); well-respected for breach handling.
<i>Hiscox</i>	Tailored small business coverage for cyber extortion, business interruption, and data recovery.	Up to \$2 million	\$0–\$10,000	Affordable; ideal for smaller companies	4.9/5 rating (Advisor Smith); 3.7/5 on Trustpilot for service quality.

Policy Recommendation: Beazley Breach Response (BBR)

Beazley’s Breach Response (BBR) policy is recommended for Sentinel Shield based on the following reasons:

- **Industry-Specific Coverage:** Beazley has deep experience handling incidents in financial services, which aligns with Sentinel Shield’s primary client base.
- **Comprehensive Breach Services:** Their policy offers immediate access to breach coaches, forensic experts, PR firms, and regulatory attorneys, minimizing downtime and reputational damage.
- **Affordability:** Beazley’s premiums are cost-effective for a company of Sentinel Shield’s size, offering significant protection without enterprise-level pricing.
- **Focus on Regulatory Compliance:** Their policies explicitly support GLBA and PCI DSS compliance efforts, which is critical for our financial sector clients.
- **Positive Market Reputation:** Beazley is consistently rated highly for claims handling and breach response effectiveness.

Given Sentinel Shield's estimated \$4.5–\$9.5 million financial exposure per major event and critical need for both first-party and third-party protection, Beazley’s policy offers the right balance of risk coverage, responsiveness, and affordability. Choosing Beazley positions Sentinel Shield to recover quickly from an incident, fulfill regulatory requirements, and maintain client trust during a crisis.

Part 4 – Readiness Assessment Checklist

1. Sentinel Shield must have the following cybersecurity controls in place to qualify for the recommended cyber insurance policy:

<i>Control Area</i>	<i>Requirement</i>	<i>Status</i>	<i>Notes</i>
<i>Multi-Factor Authentication (MFA)</i>	Implement MFA for all administrative and client-facing systems.	☐	Partially implemented; expand to all portals.
<i>Encrypted Data Backups</i>	Maintain daily encrypted backups with offsite/cloud storage.	☒	Fully implemented; verify backup testing procedures quarterly.
<i>Formal Incident Response Plan</i>	Maintain an updated and tested IR plan, including ransomware and breach response.	☒	IR plan exists; scheduled tests are semi-annual.

<i>Endpoint Detection and Response (EDR)</i>	Deploy EDR solutions across all endpoints (servers, workstations, mobile).	☒	Completed in Q1 2026.
<i>Vulnerability Management Program</i>	Conduct monthly scans and quarterly penetration tests.	☒	Penetration testing program in place.
<i>Security Awareness Training</i>	Conduct mandatory cybersecurity training for employees at least annually.	☐	Quarterly training active; refresh phishing simulation campaigns.
<i>Third-Party Risk Management</i>	Implement processes to assess and monitor vendor cybersecurity practices.	☐	Currently informal; formal vendor risk assessments needed.
<i>Access Controls</i>	Enforce least privileged access and regular user account reviews.	☒	Access control policies in place; need semi-annual audit enforcement.
<i>Encryption Standards</i>	Encrypt sensitive data at rest and in transit.	☒	Fully implemented; periodic key management reviews recommended.
<i>Disaster Recovery and Business Continuity Plan</i>	Maintain and test disaster recovery plans annually.	☐	Disaster recovery plan exists; tabletop test scheduled Q3 2026.
<i>Cloud Security Configurations</i>	Audit and harden cloud environments according to best practices (e.g., CIS Benchmarks).	☐	Initial configurations completed; conduct third-party audit.

<i>Gap</i>	<i>Description</i>	<i>Action Needed</i>	<i>Target Completion</i>
<i>MFA Expansion</i>	Extend MFA to all client-facing systems and user logins.	Deploy MFA on client portals and enforce MFA on all employee logins.	30 days
<i>Vendor Risk Management</i>	Implement a formal third-party cybersecurity assessment process.	Develop a standardized vendor risk questionnaire and review process.	60 days

<i>Disaster Recovery Testing</i>	Disaster recovery plans need formal, documented testing.	Conduct a tabletop recovery exercise and update documentation.	60 days
<i>Cloud Security Hardening</i>	Full audit needed to verify cloud configurations meet industry standards.	Hire a third-party auditor or conduct CIS Benchmark assessments internally.	90 days

Part 5 – Post-Incident Policy Utilization Plan

1. **Immediate Response and Claim Initiation:** In the event of a cyber incident (such as a ransomware attack, data breach, or business email compromise), Sentinel Shield will follow this structured, step-by-step process:
 - **Step 1: Incident Detection and Triage**
 - The Security Operations Center (SOC) or Incident Response (IR) Team will detect and triage the incident.
 - Initial documentation will capture time of detection, nature of the breach, impacted systems, and affected data.
 - **Step 2: Contain and Mitigate**
 - Immediate containment procedures will be executed (e.g., network isolation, system shutdowns, credential resets).
 - Preserve forensic evidence according to chain-of-custody best practices.
 - **Step 3: Notification of Cyber Insurance Carrier**
 - Notify the cyber insurance carrier within 24 hours of discovery, in accordance with policy reporting requirements.
 - Provide:
 - Incident report summary
 - Impacted systems/data
 - Timeline of events
 - Initial assessment of damages
 - **Step 4: Engage Carrier-Approved Resources**
 - Work with insurer-approved vendors for:
 - Digital forensics and incident investigation
 - Crisis communications and PR management

- Regulatory compliance support
- Legal consultation
- Ensure use of pre-approved vendors to avoid claim denial.
- **Step 5: Submit a Preliminary Claim**
 - Prepare and submit an initial claim, including:
 - Description of the incident
 - Estimated financial losses (downtime, remediation costs, legal fees, penalties)
 - Vendor invoices and forensic findings (as they become available)

2. Ongoing Communication and Claim Management

- Maintain ongoing communication with the assigned insurance adjuster.
- Submit all requested documents promptly, including:
 - Updated incident timeline
 - Final forensic reports
 - Regulatory notifications
 - Breach notification letters (if applicable)
- Review any policy sub-limits and ensure that specific costs (e.g., breach notification, credit monitoring services) are categorized correctly for maximum reimbursement.

3. **Policy Assistance in Recovery:** The selected cyber insurance policy will directly assist Sentinel Shield in the following ways:

<i>Support Area</i>	<i>Description</i>
<i>Forensic Investigation Costs</i>	Covers professional analysis to determine breach cause, scope, and remediation steps.
<i>Legal Support</i>	Covers legal counsel to navigate regulatory reporting, class action defenses, or government inquiries (especially important for financial sector compliance like GLBA or PCI DSS).
<i>Public Relations and Crisis Communication</i>	Funds external PR teams to manage brand reputation and customer trust post-incident.

<i>Data Recovery and Business Interruption</i>	Covers restoration of corrupted or stolen data and compensates for lost revenue due to service downtime.
<i>Regulatory Fines and Penalties</i>	Reimburses costs from regulatory actions or fines associated with privacy or financial regulations.
<i>Ransomware Negotiation and Payment (if applicable)</i>	Provides experts and funds to handle ransomware negotiations legally and ethically.

4. **Policy Limitations and Considerations:** While cyber insurance provides crucial recovery assistance, Sentinel Shield must be aware of the policy's potential limitations, including:

<i>Limitation</i>	<i>Impact</i>	<i>Mitigation Strategy</i>
<i>Strict Reporting Deadlines</i>	Late notification could invalidate coverage.	Maintain 24/7 SOC monitoring and mandate immediate reporting internally.
<i>Prior Conditions Requirements</i>	Insurers may require evidence of security controls (MFA, incident response plan) at the time of breach.	Maintain up-to-date cybersecurity documentation and security audits.
<i>Exclusion of Acts of War</i>	State-sponsored attacks could be excluded if classified as an act of war.	Choose a policy with a cyberterrorism endorsement.
<i>Vendor Approval Requirement</i>	Only insurer-approved vendors' costs may be reimbursed.	Maintain an up-to-date insurer-approved vendor list before any breach.
<i>Sub-Limits</i>	Certain categories (e.g., PR support, notification costs) may have lower maximum payouts than general policy limits.	Understand sub-limits ahead of time and plan additional budget if needed.

Appendix A – Company Background

Company Name: Sentinel Shield

Industry: Managed IT Services for Financial Institutions

Size: Approximately 20 full-time employees, with support for scalability through contractor

partnerships.

Data Stored:

- Client Financial Records (Banking, Investment, Lending Institutions)
- Personally Identifiable Information (PII)
- Payment Card Information (PCI Data)
- Internal IT System Logs and Forensic Data
- Vendor and Partner Contracts

Security Posture (as of 2026):

- **Network Security:** Firewall and intrusion detection systems are active.
 - **Authentication:** Multi-Factor Authentication (MFA) enabled for administrative accounts; MFA implementation expanding to client portals.
 - **Backup Strategy:** Encrypted, redundant cloud backups are performed daily and stored in geographically diverse data centers.
 - **Incident Response Plan:** Established and tested semi-annually; includes ransomware response, DDoS attack playbook, and breach notification processes.
 - **Employee Training:** Staff undergo mandatory cybersecurity awareness training quarterly.
 - **Vulnerability Management:** Monthly vulnerability scans with quarterly penetration testing.
 - **Recent Improvements:** Upgraded endpoint detection and response (EDR) systems deployed across all client-facing assets in Q1 2026.
-

References:

Beazley. (n.d.). Cyber insurance USA. Beazley Group. Retrieved April 27, 2025, from <https://www.beazley.com/en-US/products/cyber-usa/>

Chubb. (n.d.). Cyber insurance. Chubb. Retrieved April 27, 2025, from <https://www.chubb.com/us-en/business-insurance/products/cyber-insurance.html>

Cyber Magazine. (2023, January 19). Top 10 cyber insurance companies. Cyber Magazine. <https://cybermagazine.com/top10/top-10-cyber-insurance-companies>

Hiscox. (n.d.). Cyber security insurance for small businesses. Hiscox USA. Retrieved April 27, 2025, from <https://www.hiscox.com/small-business-insurance/cyber-security-insurance>

J.P. Morgan. (2023, March). Understanding cyber insurance: Key insights for businesses

[White paper]. <https://www.jpmorgan.com/content/dam/jpm/commercial-banking/insights/cybersecurity/761706-JPM-Whitepaper-cyber-insurance-Final-ADA.pdf>

Reinsurance News. (2023, February 7). Top 20 U.S. cyber insurance companies.

Reinsurance News. <https://www.reinsurancene.ws/top-20-us-cyber-insurance-companies/>